

Modularity is the Key

A New Approach to Social Media Privacy Policies

Sanchari Das
Indiana University
Bloomington
sancdas@iu.edu

Jayati Dev
Indiana University
Bloomington
jdev@iu.edu

Kaushik Srinivasan
Indiana University
Bloomington
kausrini@iu.edu

ABSTRACT

Social media privacy policies are the legal documents which provide inside information about the collection, storage, and access to user data. These policies are often long and convoluted for an average internet user to comprehend. Agreeing to such policies without proper knowledge is dangerous for a user's online privacy and security, mirroring to offline impacts as well. Prior work has largely concentrated on improving the accessibility of these privacy policies, but does not address the need for the flexibility in the user's choice. Our study examines the existing social media privacy policies, especially that of Facebook and targets to map the policy statements to the distinct services offered. Our proposed Modularized Privacy Policy Model (MPPM) allows users to agree to specific services which they wish to use. Modularizing the privacy policies based on the services creates a service-policy map for developers which lets them easily tie in new features to the corresponding functionality of social media platforms.

ACM Classification Keywords

H.5.m. Information Interfaces and Presentation (e.g. HCI): Miscellaneous;

Author Keywords

Social Media; Privacy Policy; Facebook; Usable Privacy and Security; Data Protection; Data Security.

INTRODUCTION

Social media privacy policies are legal documents which creates a contract between organizations and users about data collection, storage, or usage practices. These policies are arduously long, averaging over 2500 words [18], and rarely read by people [13]. About 59% of internet users have never read a privacy policy [1] and are thus, less perceptive to the extent of data that is being collected from them by an online website or service. Users are frequently resigned to read them, believing they have no control over their data [25]. Even if they are read, these policies are largely vague about the nature and extent of the data being used and stored [21].

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

MexIHC'18, Oct 29–31, 2018, Merida, Mexico
© 2018 Association for Computing Machinery.
ACM ISBN 978-1-4503-6653-3/18/10...\$15.00
<https://doi.org/10.1145/3293578.3293589>

Additionally, the choice of accepting a privacy policy is binary [4]. This means that users are forced to either agree to the privacy policy entirely or forego the possibility of not using the particular web or mobile application which has put forward the policy. Once they accept the policy during the registration or installation process, they are only notified of the subsequent policy updates and do not really have a choice in rejecting all or parts of the policy later on. This is especially problematic for websites that collect a lot of user data.

Facebook is among the leading social media platforms across the globe. It has an extensive privacy policy and a separate policy for web cookies as well. It mentions what data the platform is collecting from the users and asks the users to periodically review their data shared¹. Facebook has included unique features such as, '*Privacy Check*' to enable users to stay updated and lock-down their privacy preferences. These routine check-ups are intended to provide more data access clarity and transparency to the users. '*Privacy Basics*'² has been implemented by Facebook to educate users about how their privacy settings can be controlled to enhance their experience. All of the features make Facebook's privacy policy, which it refers to as the '*Data Policy*' interchangeably, a sufficiently detailed policy and pro-use among those available online. However, it has been noted that even Facebook's Data Policy is seldom read [10]. Even after modifications for data policies after the General Data Protection Regulations [3, 22] in the face of recent incidents and data breaches especially that of Cambridge Analytica³, these policies remain binary in nature, requiring users to agree to the policy in its entirety.

In our study, we propose a Modularized Privacy Policy Model (MPPM) where we break down social media privacy policies, exemplified by Facebook's data policy into modules. The proposed model helps the users to enroll for only those services for which they want to share their data and thus can agree to the entire privacy policy of a platform or choose based on their requirements. Thus, our goal is to enhance the effectiveness of such policies and reduce its complexity for the readers to comprehend in a better way. Our proposed model, enhances readability and clarity of such data access policies and provides the opportunity to the user to control their data access by any platform, with the option of only accepting sections they agree to.

¹<https://www.nytimes.com/2018/01/12/technology/facebook-news-feed-changes.html>

²<https://www.facebook.com/about/basics>

³<https://www.nytimes.com/2018/03/19/technology/facebook-cambridge-analytica-explained.html>

In the following sections, we establish the need for adopting modularity in the online privacy policies and discuss enhancing the usability of such legal documents. We start with the background literature on online privacy policies, followed by description of our developed MPPM. We conclude the paper by discussing our future scope of expanding to the user based study to test the proposed MPPM.

RELATED WORK

Facebook's privacy policy is ranked second in terms of terminology and clarity⁴. Even then, it requires '*college-level reading skills*'⁵ for an average internet user to read through each of these legal documents. To improve readability and usability of privacy policies, Platform for Privacy Preferences (P3P) project was developed [8]. P3P tested the privacy policy of a user visited website or online service to confirm with the privacy preferences of the user [6, 2]. Teltzrow and Kobsa extended the P3P concept to determine two alternatives of user-adaptive interfaces: First, allow a user to access the website using personal identification if P3P protocol is satisfied. Second, allow anonymous user exploration if P3P is not satisfied by using '*interface attributes*' instead of raw personal data [23], which fits into the broader definition of security in personalization.

To enhance privacy communication Mandal et al. developed a software which implemented graphical user interface to show the user privacy settings and display advisory notices in the interface to guide privacy-enhancing decisions [17]. User recommendations were built for data access permissions and incorporated security-aware personalization for mobile applications [27]. These recommendations provided detailed hardware control [12] by implementing a '*Privacy Controller Approach*' towards protection in online services [26]. However, the focus of such research is usually on e-commerce platforms rather than social media platforms. Researchers have also focused on automating the generation and study of privacy policies. Tondel et al. proposed a similarity indexing between privacy policies by making them machine-readable [24]. Sadly, these techniques have been rarely adopted by end users, given the relative challenges in deployment.

Nevertheless, the goal of user-interacting systems is to increase the efficacy by simplifying functionality for users and enhancing usability [9]. The challenge is that prior knowledge about users is required to address personal and cultural biases [11] and '*implementing a personalized interface*' can prove to be difficult for a '*variety of tasks*' [14]. In order to generate the preference-specific interface, every individual's usage, behavior, attitudes, and environment variables should be considered [16]. Cranor showed that data collection using these variables must be done following the Fair Information Practice Principles (FIPP) which prohibits collection of unnecessary data without proper knowledge and consent of the users [7]. Thus, an ideal policy structure incorporates both ease of use and champions transparent data collection practices.

Our model development is influenced by previous rich literature and we propose MPPM specifically for social media data which can be adapted by other platforms.

MODEL DEVELOPMENT

Facebook's current privacy settings allow the users to set information access control for other Facebook users. However, the Facebook's data collected is legally unhindered by the privacy settings of a user. Our goal is to provide transparency about data collection and also provide feature-based opt-in system to consent for such data collection. As privacy policies act as a document for informed consent, collecting data explicitly denied by the user would be in violation of privacy laws, providing assurance to the user and building trust for the platform (Facebook). In Donald A. Norman's '*Design of Everyday Things*' [19], the importance of a conceptual model for true understanding of how a design works is mentioned. We establish on the concept and develop a conceptual model of how a privacy policy notice should appear to the user. We aim to ensure that privacy is communicated in a simple, lucid manner and, we focus on the following concepts:

- A conceptual model to elucidate policy statement for each of the services offered.
- Improve clarity and visibility in the policy model through simplification of such statements.

In this paper, we propose a Modular Privacy Policy Model, divided into sections according to the respective services offered by Facebook. It allows users to agree to specific sections of a privacy policy and opt-out from data collection for services which they do not want to use.

Approach

Generic user modeling systems [15] provide a basic framework for studying how users value their privacy. In networked systems and services, it is becoming increasingly complex to understand and resolve conflicting privacy values and usability issues. Preibusch et al. discuss social networks need to be studied in greater detail for their data collection schemes [20]. Along the same lines, we develop a policy structure that is easy to read, and hence, usable from the consumer's perspective.

Development

Since user-adaptive interfacing is the next generation tool for businesses to expand their user base, it is important to have privacy embedded at the very basic level of software implementation [5]. Similarly, it would be convenient for software developers to implement policy statements for new services at the design level by extending the concept of '*Privacy by Design*' at the data policy level. We implement a policy design by following the design iterations mentioned below:

1. Study the current Data Policy by Facebook, that is applicable across all of its offered services. This can be done for any privacy policy as well.
2. Develop sections for classification derived from the Data Policy. This essentially means listing all the services, and checking if there are mentions of specific data collected and corresponding policy statements for data collection, usage and storage for each of these services.
3. Extract sections from policy and fit into the classification for service to policy mapping for each of these services.

⁴<http://time.com/3986016/google-facebook-twitter-privacy-policies/>

⁵<https://news.engin.umich.edu/2017/10/nobody-reads-privacy-policies-heres-how-to-fix-that/>

At the end of this step, we should obtain a paragraph of information as shown as an example below:

Find Friends Service - Used to find other Facebook users⁶ with commonalities like location, mutual friends or like-wise.

Data Collected

- User contact information.
- User's network contact information.
- Contact information which is uploaded, synced or imported from address books by the user on any device that connects to Facebook application.

Data Usage The service use the data to make friend suggestions to the Facebook user ('*People You May Know*').

Data Storage As long as necessary for an active account. Information about users shared by others will not be deleted even if users delete their account.

4. Develop the modular sections of the policy based on the extracted data. Our model expresses the data access by segregating it with respect to the services, in the following manner, as exemplified by Figure 1.
5. Validate the usability of the modular policy by conducting a pilot study. A usability study would typically involve users going through the proposed model and responding if it would make a difference in their willingness to read or use it, in comparison to the already existing data policy.

The final model can be used by developers at the organizational level to insert policy statements for new services they may choose to add. At the user end, these service-specific policy statements can be seen and accepted in parts according to the particular services they desire. The different sections that we have formed in the modular policy can be broadly classified into the following categories - (a) Services offered (b) Data collected (including permissions like microphone, camera, etc.) (c) Data Usage (d) Default consent settings (e) Data storage and, (f) Length of Data Storage.

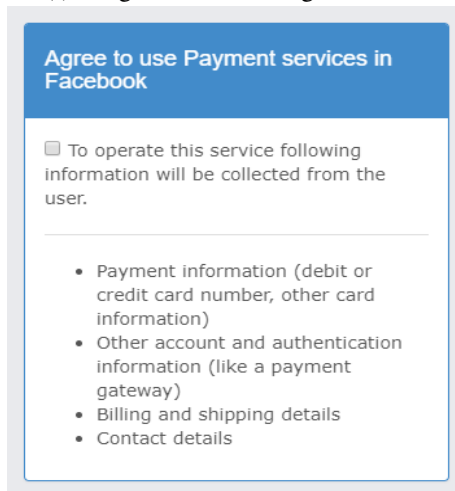


Figure 1. Modularized Facebook Privacy Policy Interface

Pilot Study and Future Work

One of the key takeaways while designing the MPPM was that enumerating the different sections of the policy reveal many gaps in the actual policy statement. For example, it was not clear if certain services like Messenger and Advertisements stored user information for a longer time than necessary or where and how they stored such information. Additionally, it further reaffirms privacy policies have '*vague statements*' [21] as described by Reidenberg et al.

To gather insights on our model, we designed a few open-ended questions and conducted a pilot study with eight individuals. Suggestions from participants during the pilot study revealed that most participants were more likely to read the modular privacy policy over the actual data policy, even though they were not used to reading them in the first place. Due to ethical concerns, we cannot report on the details of the interviews conducted, thus, as a future work, we want to extend our proposal to conduct usability research as a progression to study the impact of the current work. Through qualitative and quantitative user studies we can estimate the strength of the MPPM by incorporating user suggestions.

Additionally, we also want to extend our work to other platforms such as Internet of Things (IoT) devices and other online platforms and services to test its efficacy and generalizability to other platforms. Data accessibility and storage has been a point of concern both from the users' as well as the developers' perspective and an extension of our proposal will have a positive impact especially for organizations like hospitals, insurance, and financial corporations which store sensitive data.

LIMITATIONS

In an attempt to condense a verbose privacy policy which factors in legal terminology, it is likely that certain subtleties might be lost. Our proposal is not targeted at a technical or legal expert and we wanted to keep the wording of the policy readable and understandable by general population. We acknowledge that some users may not read privacy policies and they usually skim through it briefly and hence we provided short phrases to describe data collection process. With implementation of MPPM, we acknowledge that some of the services cannot be used unless the data access permission is granted to the platform by the users. But, we target on the clarity of user data privacy policies for the users to take an informed decision.

CONCLUSION

The MPPM proposed in this paper provides simplifying the privacy policies by providing easily readable service-based data collection details. Users can opt-in for partial data collection based on the services they use and selectively reject other services' data collection policies within a platform. This provides the user with an opportunity to take control of their privacy by selectively agreeing to only sections of the privacy policy, for services they want. Our proposal enhances transparency within an organization from the developer's perspective since we believe developers will find it more convenient to implement clear data collection schemes through the MPPM; the modifications in particular services will also impact a particular section of the policy instead of the whole document.

⁶<https://developers.facebook.com/policy>

MPPM clearly displays which services collect what kind of data from the users and the users can decide whether they want to give the data access permissions for that particular services. This would be an important factor in persuading organizations to adopt our proposed privacy model since it will enhance trust between a user and the company implementing such user-centric approach. Additionally, though our initial study was based on Facebook's data policy, it can be very well extended to privacy policies for other platforms as well, adjusted according to the services offered.

ACKNOWLEDGEMENT

We would like to thank Dr. Sameer Patil for the valuable insights and all our pilot study participants for their feedback.

REFERENCES

1. Alessandro Acquisti and Jens Grossklags. 2005. Privacy and rationality in individual decision making. *IEEE Security & Privacy* 3, 1 (2005), 26–33.
2. Oliver Berthold and Marit Köhntopp. 2001. Identity management based on P3P. In *Designing privacy enhancing technologies*. Springer, 141–160.
3. Giovanni Buttarelli. 2016. The EU GDPR as a clarion call for a new global digital gold standard. (2016).
4. Fred H Cate. 2010. The limits of notice and choice. *IEEE Security & Privacy* 8, 2 (2010).
5. Ann Cavoukian. 2009. Privacy by design. *Take the challenge. Information and privacy commissioner of Ontario, Canada* (2009).
6. Ibrahim Cingil, Asuman Dogac, and Ayca Azgin. 2000. A broader approach to personalization. *Commun. ACM* 43, 8 (2000), 136–141.
7. Lorrie Faith Cranor. 2004. I didnt buy it for myself. In *Designing personalized user experiences in eCommerce*. Springer, 57–73.
8. Lorrie Faith Cranor, Praveen Guduru, and Manjula Arjula. 2006. User interfaces for privacy agents. *ACM Transactions on Computer-Human Interaction (TOCHI)* 13, 2 (2006), 135–178.
9. Sanchari Das, Andrew Dingman, and L Jean Camp. 2018. Why Johnny Doesn't Use Two Factor A Two-Phase Usability Study of the FIDO U2F Security Key. In *2018 International Conference on Financial Cryptography and Data Security (FC)*.
10. Bernhard Debatin, Jennette P Lovejoy, Ann-Kathrin Horn, and Brittany N Hughes. 2009. Facebook and online privacy: Attitudes, behaviors, and unintended consequences. *Journal of Computer-Mediated Communication* 15, 1 (2009), 83–108.
11. Jayati Dev, Sanchari Das, and L Jean Camp. 2018. Privacy Practices, Preferences, and Compunctions: WhatsApp Users in India. In *12th International Symposium on Human Aspects of Information Security Assurance (HAISA)*.
12. Adrienne Porter Felt, Kate Greenwood, and David Wagner. 2011. The effectiveness of application permissions. In *Proceedings of the 2nd USENIX conference on Web application development*. 7–7.
13. Martin Fishbein and Icek Ajzen. 1977. Belief, attitude, intention, and behavior: An introduction to theory and research. (1977).
14. Peter A Hancock and Mark H Chignell. 1988. Mental workload dynamics in adaptive interface design. *IEEE transactions on Systems, Man, and Cybernetics* 18, 4 (1988), 647–658.
15. Alfred Kobsa. 2001. Generic user modeling systems. *User modeling and user-adapted interaction* 11, 1 (2001), 49–63.
16. Alfred Kobsa and Jörg Schreck. 2003. Privacy through pseudonymity in user-adaptive systems. *ACM Transactions on Internet Technology (TOIT)* 3, 2 (2003), 149–183.
17. Ayan Kanti Mandal, Yuan Xie, David Luke Richardson, Cherry Mangat, Nam Huy Bui, Derek Joseph Halliday, and Arunsunai Anbukarasi Anbalagapandian. 2015. Mobile communication device display with graphical user interface comprising security and privacy advisor screens. (Jan. 6 2015). US Patent D720,766.
18. Aleecia M McDonald and Lorrie Faith Cranor. 2008. The cost of reading privacy policies. *ISJLP* 4 (2008), 543.
19. Don Norman. 2013. *The design of everyday things: Revised and expanded edition*. Basic Books.
20. Sören Preibusch, Bettina Hoser, Seda Gürses, and Bettina Berendt. 2007. *Ubiquitous social networks: Opportunities and challenges for privacy-aware user modelling*. Technical Report. DIW Discussion Papers.
21. Joel R Reidenberg, Jaspreet Bhatia, Travis D Breaux, and Thomas B Norton. 2016. Ambiguity in privacy policies and the impact of regulation. *The Journal of Legal Studies* 45, S2 (2016), S163–S190.
22. Beata A Safari. 2016. Intangible Privacy Rights: How Europe's GDPR Will Set a New Global Standard for Personal Data Protection. *Seton Hall L. Rev.* 47 (2016), 809.
23. Maximilian Teltzrow and Alfred Kobsa. 2004. Impacts of user privacy preferences on personalized systems. In *Designing personalized user experiences in eCommerce*. Springer, 315–332.
24. Inger Anne Tøndel and Åsmund Ahlmann Nyre. 2012. Towards a similarity metric for comparing machine-readable privacy policies. In *Open Problems in Network Security*. Springer, 89–103.
25. Joseph Turow, Michael Hennessy, and Nora A Draper. 2015. The tradeoff fallacy: How marketers are misrepresenting American consumers and opening them up to exploitation. (2015).
26. George OM Yee. 2007. A privacy controller approach for privacy protection in web services. In *Proceedings of the 2007 ACM workshop on Secure web services*. ACM, 44–51.
27. Hengshu Zhu, Hui Xiong, Yong Ge, and Enhong Chen. 2014. Mobile app recommendations with security and privacy awareness. In *Proceedings of the 20th ACM SIGKDD international conference on Knowledge discovery and data mining*. ACM, 951–960.